

TYPE 1

READINESS & REFERENCE

SOC 2 Type 1

A point-in-time attestation of whether your controls are **suitably designed and implemented** as of a specific date — what it is, what the auditor tests, the evidence to prepare, and how it sets up a future Type 2.

**Point-
in-time**

"AS OF" A
SINGLE DATE

Design

SUITABILITY &
IMPLEMENTATION

3–6 mo

TYPICAL
TIMELINE

Stepping stone

LEADS TO TYPE 2

Framework basis: AICPA TSP Section 100 — Trust Services Criteria (2017, with 2022 revised points of focus); SOC 2 examination guidance under AT-C 205. • **Prepared:** 30 July 2026 • Internal readiness aid.

1 — What a Type 1 report is

A Type 1 report evaluates the **suitability of design and implementation** of controls **as of a single specified date**. It answers: "Are the right controls in place and properly designed *today*?" It does **not** test whether they operated effectively over a period — that is a Type 2.

The one distinction that changes everything: because Type 1 is a snapshot, **point-in-time evidence is sufficient** — a current policy, a configuration screenshot, today's access list. You do **not** need to prove a control fired repeatedly across months. (That "must span the whole observation period" rule is Type 2.)

Type 1 vs Type 2 at a glance

Dimension	SOC 2 Type 1	SOC 2 Type 2
Question answered	Are controls suitably designed & implemented as of a date?	Did controls operate effectively across a period?
Time coverage	Point-in-time ("as of [date]")	Observation period (commonly 3–12 months)
What's tested	Design suitability + implementation (in place on the date)	Design + operating effectiveness over time
Evidence needed	Current-state snapshot per control	Recurring evidence spanning the whole period
Auditor methods	Inquiry, observation, inspection, walkthroughs	All of Type 1 plus sampling & reperformance across the period
Report Section IV	Lists controls tested — no test procedures / results columns	Controls plus auditor tests, results, and any exceptions
Typical timeline	~3–6 months	~6–15 months (includes the observation period)
Best when	Controls newly implemented; need to prove design quickly to close a deal	Buyers require sustained assurance; renewals; mature program

2 — The "as of" date & what the auditor tests

The report is dated "as of" a specific day. The auditor forms an opinion on two things as of that day: (1) whether management's **system description** is fairly presented, and (2) whether the controls are **suitably designed and implemented** to meet the Trust Services Criteria in scope.

The four testing methods (design & implementation focus)

Method	What the auditor does	Example for a Type 1
Inquiry	Asks personnel to explain how a control is designed and who operates it.	Interview the IAM lead on the access-provisioning process.
Observation	Witnesses a control in action or a configuration in its current state.	Watch an MFA challenge on the production console login.
Inspection	Reviews documents, policies, and artifacts as they exist on the date.	Inspect the encryption policy and a current TLS scan report.
Walkthrough	Traces a control end-to-end once to confirm it is designed and in place.	Walk a single change from PR → review → approval → deploy.

Type 1 nuance — "implemented," not just "documented." A written policy alone is not enough. The auditor confirms the control actually **exists and is in place** on the report date (e.g. MFA is genuinely enforced, encryption is genuinely on). A control that is documented but not yet operating is a **design/implementation gap**.

3 — What's inside a Type 1 report

A SOC 2 report has four sections. In a Type 1, Sections I–III mirror a Type 2, but Section IV lists the controls **without** the auditor's tests-and-results detail (there is no operating-effectiveness testing over a period).

§	Section	What it contains
I	Independent auditor's opinion	The CPA's opinion that, as of the date, the description is fairly presented and controls are suitably designed & implemented. Opinion may be unqualified, qualified, adverse, or a disclaimer .
II	Management's assertion	Management's written assertion that the description is accurate and controls are suitably designed as of the date.
III	System description	Scope, boundaries, infrastructure, software, people, data, and the relevant policies — so a reader knows exactly what was assessed.
IV	Applicable criteria & controls	The in-scope Trust Services Criteria and the controls mapped to them. Type 1: the list of controls only — no test procedures, no results, no exceptions columns.

4 — The Type 1 roadmap

A first-time Type 1 typically runs about 3–6 months across three phases. The bulk of the effort is the readiness work before fieldwork.

PHASE 1

Readiness & prep

1–3 months

Define scope & the "as of" date, implement controls, write policies, assign owners, run a gap self-assessment, select a CPA firm.

PHASE 2

Fieldwork

2–5 weeks

Auditor reviews control design, runs walkthroughs, and inspects current-state evidence for each in-scope control.

PHASE 3

Report

2–6 weeks

Auditor drafts and issues the report with the opinion, description, and control list.

Scoping decisions to lock first: which Trust Services Categories are in scope (Security is mandatory; add Availability / Confidentiality / Processing Integrity / Privacy as commitments require), the system boundary, and the single "as of" date. Everything else follows from these.

5 — Design-suitability check (per control)

For a Type 1, each control has to pass a four-part test as of the report date. Use this as a self-assessment before fieldwork.

#	Test	The question to answer "yes" to
1	Exists	Is there a defined control addressing the risk (not just an intention)?
2	Documented	Is it written into a policy / procedure with an owner?
3	Implemented	Is it actually in place and operating on the "as of" date (configuration proves it, not just the policy)?
4	Mapped	Does it clearly satisfy one or more in-scope Trust Services Criteria?

Point-in-time evidence — in-scope controls

For Type 1, each item below is captured as a **current-state snapshot** dated on/near the "as of" date. (These are the 13 controls in the example scope; the criteria mapping is verified against AICPA TSP Section 100.)

Control	Criteria	Design / implementation evidence to have ready (as-of date)
Securing Data in Transit & At Rest	CC6.1, CC6.7	Encryption policy; current TLS scan (1.2/1.3); DB TDE + storage-encryption screenshots; KMS/Key Vault config.
Designated Customer Email	CC2.2, CC2.3	Documented support/security contact process; live monitored mailbox; escalation procedure.
User Credentials & Passwords	CC6.1–6.3	Password policy; current IdP/MFA config screenshot; RBAC export; most recent access review.
Software & Hardware Changes	CC8.1	Change-management policy; a walkthrough of one recent change (PR + approval + test).
Restricted Production Changes	CC6.1, 6.3, 8.1	Current production access list; IAM/RBAC export; deploy-permission & branch-protection settings.
Approved Changes Pre-Implementation	CC8.1	Policy requiring approval; one example approved change with reviewer sign-off + rollback note.
Separation of Environments	CC8.1 (impl. control)	Architecture diagram; separate account/subscription list; namespace / IaC env configs.
Data Retention / Backups	A1.2, A1.3, C1.2	Retention & backup policy; current backup config + latest success log; most recent restore-test record; RTO/RPO.
System Training	CC1.4, CC2.2	Training policy & curriculum; current completion roster showing in-scope staff are trained.
System Diagram	Description Criteria; CC2.1–2.3	Current, dated network / data-flow diagram reconciled to the live architecture.
Remote User Access MFA	CC6.6	MFA-enforced screenshots per external system; VPN/zero-trust & conditional-access config.
Vulnerability Scans	CC7.1, CC4.1	Scanner config + most recent scan report; open-findings tracker showing remediation in progress.
Patching	CC7.1, CC6.8	Patch policy with severity SLAs; current patch-status report from patch/config tooling.

6 — Common Type 1 pitfalls & the path to Type 2

Because Type 1 tests design, the exceptions look different from Type 2 — they're about controls that are missing, un-implemented, or mis-mapped on the date, rather than controls that lapsed over a period.

- **Documented but not implemented:** a policy exists but the control isn't actually live on the date (e.g. MFA in advisory mode, encryption not switched on) — the classic Type 1 design/implementation gap.
- **System description doesn't match reality:** the diagram or boundary in Section III differs from the live environment the auditor walks through.
- **Orphan controls:** a control that doesn't clearly map to an in-scope criterion, or an in-scope criterion with no control addressing it.
- **Scope drift:** including optional categories (Privacy, Processing Integrity) whose criteria don't apply, forcing "not applicable" entries and extra cost.
- **Stale snapshot:** evidence captured too far from the "as of" date.

Type 1 → Type 2. A Type 1 proves the design is sound on day one; a Type 2 then proves those same controls **operated** across the following months. The practical move: pass Type 1, then immediately start the Type 2 observation period, keeping the same controls and now collecting **recurring, dated evidence** (access reviews, change tickets, scan reports, restore tests) throughout the window.

Authoritative sources: AICPA *TSP Section 100 — Trust Services Criteria* (2017, with 2022 revised points of focus) for the criteria; SOC 2 examination performance & reporting guidance under the AICPA attestation standards (AT-C 205). Criterion mappings above were verified against the primary TSP Section 100 text.

This document is an internal readiness aid. It does not constitute an audit opinion, certification, or legal advice. Only a licensed CPA firm can perform a SOC 2 examination and issue a report.